النسخة العربية · الإصدار 1.0

وثيقة الإمتثال والجودة والحوكمة بالحد الأقصى وإستخدام البيانات بالحد الادنى

المرجع المؤسسي المعتمد لدى شركة رجال الوطن القابضة

تجربة أبسط، وبيانات أقل، وقرارات مسؤولة قابلة للإثبات

من إعداد اسماعيل التميمي

المرجع المؤسسي المعتمد لدى شركة رجال الوطن القابضة

5 نوفمبر 2026

الفهرس التفاعلي

الفهرس التفاعلي

اضغط على عنوان الفصل للانتقال إليه؛ زر «الفهرس» أسفل كل صفحة يعيدك إلى هنا.

01 الاعتماد المؤسسي وبوابة التبسيط 3
02 الانطباق والمسؤوليات وسلطة القرار 3
03 رحلات الاستخدام واللوحات والإتاحة 4
04 أغراض البيانات والحد الأدنى والمسوغات 5
05 الإشعار والموافقة وحقوق أصحاب البيانات 5
06 سجلات المعالجة والسياسات المنشورة والتقييمات 6
07 الاحتفاظ والإتلاف والموردون والنقل الخارجي 7
08 الحسابات المؤسسية والهوية والصلاحيات 7
09 الإنفاذ الخادمي وواجهات التكامل والملفات 8
10 سجل الإجراءات والتدقيق ومقاومة العبث 9
11 قراءة السجلات والتصدير المأذون 9
12 البيئات والإصدارات والصيانة وجودة التنفيذ 10
13 الحوادث والتسرب وقرارات الإخطار 11
14 الاحتواء والتعافي والنسخ والاستمرارية 11
15 التجارة والمدفوعات والفوترة والخصائص المنظمة 12
16 حقوق المصنفات والمحتوى والذكاء الاصطناعي 13
17 الهوية المرنة والاستنساخ المستقل 13
18 البيع والهبة ونقل الملكية أو التشغيل 14
19 عزل الفني واستقلال التشغيل وحزمة التسليم 15
20 الموقع والويب والتطبيق التقدمي 15
21 الجوال والتوزيع والأذونات ونقل التطبيق 16
22 بوابات القبول والمواءمة والاستفادة والتصويب 17
23 المصادر المرجعية 18

01 الاعتماد المؤسسي وبوابة التبسيط

مرجعية داخلية تجعل سهولة الخدمة نقطة البدء، وتربط العناية بقرارات قابلة للإثبات.

هذه الوثيقة هي المرجع المؤسسي المعتمد لدى شركة رجال الوطن القابضة لحوكمة المواقع وتطبيقات الويب والتطبيقات التقدمية وتطبيقات الجوال، من التأسيس إلى المواءمة والتشغيل والاستنساخ والنقل والعزل والإيقاف. مرجعيتها داخلية، ويطبق كل حكم بحسب نشاط المنتج وانطباق النظام، وتتحول متطلباتها المنطبقة إلى مواصفات ومسؤوليات وأدلة قبول في ملف المنتج.

الأولوية العليا

الأولوية العليا صراحةً هي تبسيط وتسهيل تجربة الزائر والمستخدم والمالك والمشرف الرئيسي والمشرفين والجهات المعنية. يجب أن تعرض لكل دور لوحة مناسبة، وخطوات قصيرة تحفظ التفضيلات والتقدم بقدر الحاجة، دون تكرار البيانات أو الموافقات أو التسجيل الزائد أو الحجب العام. تنفذ الخلفية الضوابط الخادمية تلقائيًا، وتظهر الإشعارات والموافقات والحقوق والتكلفة الجوهرية الواجبة في موضعها.

معنى الحد الأقصى والحد الأدنى

سقف العنوان هدف جودة وعناية مهنية، وليس ضمان حصانة أو انعدام الحوادث أو انعدام الصيانة، ولا شهادة اعتماد حكومي. والحد الأدنى من البيانات يعني الاقتصار على ما يلزم لغرض معتمد، لا إلغاء بيانات لازمة لنظام أو خدمة. بساطة التجربة هدف قابل للاختبار، وليست وعدًا بأن كل ضابط أو موافقة لن يؤثر في الرحلة إطلاقًا.

بوابة القرار قبل الميزة

- تحديد حاجة المستخدم والنشاط والبيانات المطلوبة قبل اختيار التقنية أو إضافة الحسابات.
- تعيين المسؤول عن القرار والتنفيذ والمراجعة، وربط كل قبول بإصدار ودليل أداء وحقوق.
- إبقاء الخدمة العامة المشروعة متاحة، وقصر المنع على الوظيفة التي لم تستوف شروطها.

القاعدة الحاكمة

أخفِ التعقيد التشغيلي، ولا تخفِ الحقيقة أو الحقوق أو التكلفة؛ واجعل التحكم خلف الخدمة لا عائقًا عامًا أمامها.

02 الانطباق والمسؤوليات وسلطة القرار

لكل مطلب نوع واضح، ولكل قرار صاحب مسؤولية وحدود تفويض.

تصنيف المتطلبات

الأصل أنظمة المملكة العربية السعودية ولوائحها النافذة. يجب فصل الحكم النظامي الإلزامي عن شرط النشاط أو القطاع، وعن سياسة المزود أو المتجر، وعن المعيار المؤسسي. تستخدم عبارة «يجب» في هذا المرجع للمطلوب داخليًا في نطاقه، ولا تجعلها تسميةً لكل توصية على أنها قانون عام. تحفظ لكل التزام مادته أو قسمه وإصداره وسبب انطباقه ومسؤول تحديثه.

تطبق ضوابط الهيئة الوطنية للأمن السيبراني بحسب نطاقها، ومنه الجهات الحكومية وتوابعها والقطاع الخاص المرتبط بالبنى التحتية الوطنية الحساسة؛ ولا تفرض المجموعة كاملة على كل موقع خاص. وتفحص متطلبات هيئة الحكومة الرقمية عند النشاط الحكومي أو التقديم نيابةً عن جهة حكومية. لغير المشمولين يعتمد مستوى حماية متناسب، وفق واجب الحماية وأفضل الممارسات المعترف بها.[2][4]

أدوار لا تندمج تلقائيًا

يفصل مالك الأصل وصاحب الحقوق عن جهة التحكم التي تحدد أغراض المعالجة وكيفيتها، وعن المعالج العامل نيابة عنها، وعن المشغل الفني والمشرف الرئيسي. يقرر المالك التفويض والميزانية والتصرفات الجوهرية، وتعتمد جهة التحكم أغراض البيانات ومسوغاتها، وينفذ التشغيل والمطور الضوابط ضمن تكليفهما. لقب المشرف الرئيسي لا يمنح بذاته حق الاطلاع على جميع البيانات الشخصية.[1]

ملف النطاق

- توثيق الجهة والخدمة والجمهور والأسواق والقطاع، والحسابات والبيانات والموردين والمدفوعات والمحتوى والخصائص المنظمة.
- تحديد حالة كل خاصية: غير منطبقة، أو قيد التصنيف، أو معتمدة في نطاق معلوم، أو معلقة.
- تسمية صاحب قرار الإطلاق والإيقاف والنقل، والمراجع المختص والبديل التشغيلي، ولو جمع شخص أكثر من وظيفة.

قرار لا تتجاوزه الأداة

لا تبدأ وظيفة منظمة قبل تصنيفها واستكمال إذنها عند لزومه، ولا يجيز قبول المخاطر مخالفة نظامية أو تجاوز حق واجب.

03 رحلات الاستخدام واللوحات والإتاحة

تُقاس البساطة بإتمام العمل الصحيح، لا بإخفاء الخطوات الواجبة.

خدمة بحسب الدور

يبدأ الزائر بتصفح المحتوى العام دون حساب عندما تسمح الوظيفة. تقدم لوحة المستخدم خدماته وطلباته واختياراته، ولوحة المشرف أعمال نطاقه، ولوحة المشرف الرئيسي قرارات الإدارة وسجل الإجراءات، ولوحة المالك حالة الأصول والمخاطر والاعتمادات دون إغراقه بالتفاصيل الفنية. تظهر للجهة المعنية فقط المواد التي يجيزها الطلب والترخيص، عبر مسار واضح ومحدود.

يجب حفظ التفضيلات والتقدم الضروري بطريقة معلنة وآمنة، مع تمييز المسودة المحفوظة من الإجراء المنفذ. يعاد استخدام البيانات الصحيحة الموجودة بدل مطالبة الشخص بها مرة أخرى، دون جلب بيانات خارج غرضه. تقدم الأخطاء عند الحقل بلغة مفهومة، وتحفظ المدخلات السليمة، وتتيح الرجوع وتصحيح الخطأ قبل الالتزام. لا يعاد طلب موافقة قائمة لمجرد انتقال الشاشة.

العربية والإتاحة

يعتمد هدف WCAG 2.2 بالمستوى AA معيارًا مؤسسيًا للجودة، مع أي متطلب إضافي منطبق، لا ادعاء بأنه واجب موحد لكل موقع سعودي. تضبط العربية من اليمين إلى اليسار والإنجليزية من اليسار إلى اليمين، وتعزل الأرقام والبريد والروابط باتجاه مناسب دون تفكيكها. تشمل المراجعة التباين ولوحة المفاتيح والتركيز والتسميات والتكبير وقارئ الشاشة والمصادقة الميسرة.

دليل التجربة

تحدد رحلات قبول لكل دور، تشمل الزيارة والطلب والرفض والسحب والشكوى والتصدير والإدارة الحساسة. يوثق المسؤول الخطوات والتكرار والتعثر والوقت المرصود ووضوح التكلفة، ثم يعتمد أهداف التحسين بحسب خط الأساس؛ لا تستخدم أرقام أداء مختلقة. يجمع الفحص الآلي مع مراجعة بشرية للرحلة الكاملة، ولا يستبدل زر إتاحة إصلاح الواجهة.

بساطة قابلة للفحص

إذا أمكن تقليل خطوة بلا إخلال بحق أو حماية لازمة وجب تقليلها؛ وإذا لزمت خطوة وجب شرح سببها وتيسير إتمامها.

04 أغراض البيانات والحد الأدنى والمسوغات

لا حقل بلا حاجة محددة، ولا معالجة بلا مسوغ ومسؤول.

سجل الغرض

قبل الجمع، يجب تحديد كل غرض وفئات البيانات ومصادرها ومسوغها ومسؤولها ومستلميها وموردها ومدة احتفاظها أو معيار نهايتها. يربط مخطط الحقول الحاجة بكل غرض، ويشمل النماذج والملفات والسجلات والمهام الخلفية والمخرجات المشتقة. الموافقة ليست قيمة افتراضية لجميع المعالجات؛ يفحص مسوغ كل غرض وفق النظام، وتوثق شروطه قبل تشغيله.[1][2]

لا يجمع رقم الهوية الوطنية أو تاريخ الميلاد أو الهاتف أو ينشأ حساب إذا لم تكن هناك حاجة فعلية أو متطلب منطبق. ولا تجمع بيانات حساسة أو تفعل تحليلات وتتبع أو ذكاء اصطناعي خارجي افتراضيًا. إذا اقتضى النشاط استثناءً يعتمد نطاقه وتقييمه وضوابطه أولًا، وتطلب البيانات عند استخدام الوظيفة اللازمة لها، لا عند أول زيارة.

العام ليس مباحًا بلا حدود

البيانات المنشورة عن الأشخاص تظل خاضعة لأحكامها؛ إتاحتها للعامة لا تمنح مسوغًا شاملًا لإعادة الجمع أو النشر أو التدريب. يجب التأكد من مشروعية المصدر والغرض والتناسب والإشعار عند انطباقه. الترميز، بما فيه استبدال الاسم أو تجزئة معرف قابل للربط، ليس إخفاء هوية؛ يظل شخصيًا إذا أمكن إعادة التعرف. يتطلب إخفاء الهوية تقويمًا لفاعلية إزالة المعرفات المباشرة وغير المباشرة.[1][2]

تقليل القياس التشغيلي

لا يخزن عنوان الشبكة الخام تلقائيًا في كل حدث، ولا جسم الطلب كاملًا في سجلات الأخطاء. تختار أقل حقول لازمة للحماية أو التدقيق، بمسوغ ومدة وصلاحيات؛ وتحجب الأسرار والرموز والرسائل الخاصة. وعند اعتماد المصلحة المشروعة توثق الضرورة والموازنة والتوقعات المعقولة، ولا تدخل البيانات الحساسة تحت هذا المسوغ.[2]

حاجز الجمع

غرض غير محدد، أو مسوغ غير معتمد، أو حقل زائد: أسباب توقف المعالجة المعنية قبل إطلاقها، لا أسباب لإضافة موافقة عامة تغطيها لفظيًا.

05 الإشعار والموافقة وحقوق أصحاب البيانات

الحقوق مسارات تنفيذ واضحة، لا مربعات أو صفحات شكلية.

الإحاطة والاختيار

تتاح سياسة الخصوصية وتقدم المعلومات قبل أو عند الجمع المباشر: هوية جهة التحكم وتواصلها، والغرض والمسوغ، وإلزامية الحقول، والمستلمون، والاحتفاظ والحقوق والنقل الخارجي عند وجوده. لا يغني سجل التدقيق عن الإشعار. وعند الجمع غير المباشر يطبق الإبلاغ دون تأخر غير مبرر وخلال ثلاثين يومًا من التلقي، مع الفئات والمصدر، إلا باستثناء منطبق موثق.[1][2]

يفصل قبول الشروط عن العلم بالسياسة وعن الموافقات الاختيارية. عند الاستناد إلى الموافقة تكون حرة وواضحة ومستقلة لكل غرض، وتوثق بالوقت والوسيلة وإصدار النص. تتاح آلية سحب مماثلة أو أسهل من المنح، ويتوقف الغرض في الخادم والطوابير والموردين دون تأخير غير مبرر. رفض التسويق لا يمنع خدمة غير مرتبطة به، ولا تستبدل الموافقة المسحوبة بمسوغ رجعي للتحايل.[2]

طلب سهل وتحقق متناسب

توفر قنوات عملية للعلم والوصول والنسخة والتصحيح والإتمام والتحديث والإتلاف والشكوى، بما يناسب الخدمة، دون إنشاء حساب أو اشتراك للحق وحده. تستخدم الجلسة الموثقة أو قناة بديلة للتحقق المتناسب؛

ولا تطلب صورة هوية من كل طالب. تسجل الطلبات، بما فيها الشفهية، ووقت الاستلام والمسؤول والموعد والقرار والرد وأثر التنفيذ.[2][1]

مدة وتنفيذ

تنفذ طلبات الحقوق دون تأخير خلال مدة لا تتجاوز ثلاثين يومًا. يجوز تمديدها بما لا يزيد على ثلاثين يومًا إضافية عند جهد إضافي غير متوقع أو غير معتاد أو طلبات متعددة من الشخص، مع إخطار مسبق بمبررات التمديد؛ ولا يعاد بدء العداد بنقل التشغيل. تحمى حقوق الغير في النسخة، ويصل التصحيح والإتلاف إلى الأنظمة والمستلمين المعنيين.[2]

الإنجاز الحقيقي

زر الطلب بداية المسار: اكتماله رد مفهوم وتنفيذ موثق، مع بيان أي احتفاظ مشروع أو قيد منطبق، لا وعد حذف فوري لكل نسخة.

06 سجلات المعالجة والسياسات المنشورة والتقييمات

المرجع رأس حوكمة، والسياسة المنشورة وصف صادق لخدمة محددة.

سجل مؤسسي محدث

يجب إنشاء سجل أنشطة المعالجة وربطه بخريطة البيانات والأغراض والمسوغات والمستلمين والموردين والاحتفاظ والنقل والتدابير والمسؤولين. يحفظ سجل النشاط طوال استمرار المعالجة وخمس سنوات بعد انتهاء نشاطها وفق اللائحة؛ هذه مدة سجل النشاط، وليست مدة عامة للاحتفاظ ببيانات المستخدمين. يراجع السجل عند تغير حقل أو غرض أو مورد أو دولة أو وظيفة جوهرية.[2]

فحص الانطباق

يفحص وجوب تقييم أثر حماية البيانات قبل المعالجة بحسب محفزات اللائحة، ومنها الحساسة والربط بين مصادر متعددة والأنشطة المحددة واسعة النطاق أو المتكررة والتقنيات الناشئة أو احتمال الضرر الجسيم. ويفحص تعيين مسؤول حماية البيانات بحسب شروطه، ولا يسمى كل مشرف تقني مسؤولًا رسميًا. تحدد عند اللزوم استقلاليته وموارده وتواصله وبديله، وتفحص متطلبات التسجيل المنطبقة على جهة التحكم.[2]

سياسة حقائق لا قوالب

تصاغ لكل منتج سياسة خصوصية من القرارات والعقود والإعدادات الفعلية، تشمل الهوية والتواصل والفئات والمصادر والمسوغات والأغراض والتتبع والمستلمين والنقل والاحتفاظ والحقوق. لا تنشر خانات فارغة أو عبارة «لا نجمع» أو «لا ننقل» أو «لا يستخدم للتدريب» بلا واقع يؤيدها. هذا المرجع ليس السياسة المنشورة لكل نشاط، ولا يستبدل تكييفها واعتمادها.

تصاغ الشروط بإيجاز ووضوح، مع نطاق الخدمة والأهلية والتكلفة والتجديد والإلغاء وحقوق المحتوى والشكاوى والتعليق والحذف، وملحق التجارة عند انطباقه. تحفظ النسخ وتواريخ النفاذ والقبول والنص الذي قبل وقت التعاقد، ولا يعيد مالك جديد كتابة شروط الماضي أو فواتيره. لا تتضمن إعفاءً غير مشروع أو حرمانًا من حق بيانات أو مستهلك أو جهة مختصة.[14][1]

اتساق قابل للاختبار

يجب أن يستطيع الفريق إثبات كل ادعاء منشور بسلوك الخدمة وسجل قرار: النص الذي لا يمكن تنفيذه أو إثباته لا ينشر بوصفه حقيقة.

07 الاحتفاظ والإتلاف والموردون والنقل الخارجي

نهاية الغرض قرار تشغيلي، ومكان الخادم جزء من التدفق لا كله.

مدة لكل فئة

يعتمد لكل فئة موعد بداية ومدة أو معيار نهاية ومسوغ ومسؤول. تتلف البيانات بعد انتهاء الغرض دون تأخير، مع احتفاظ نظامي أو تحفظ مرتبط بقضية منظورة وضروري لها في حدوده. يعزل المحتفظ به لهذا السبب عن الاستخدامات الأخرى، ويراجع انتهاء سببه. لا يبرر احتمال احتياج مستقبلي حفظًا مفتوحًا، ولا يعد الحذف المنطقي وحده إتلافًا.[1][2]

تشمل خطة الإتلاف القواعد والملفات والفهارس والذاكرة المؤقتة والموردين والنسخ الاحتياطية. تستخدم مراجع حذف قليلة البيانات، أو علامات منع إحياء، لتطبيق أحدث قرارات الإتلاف والتصحيح والسحب قبل فتح نسخة مستعادة؛ ولا تحل هذه الآلية محل إتلاف النسخ المستحق. يثبت التنفيذ بنتائج ومراجع محدودة، وتحدد مدة سجل الحذف نفسه.[2]

المورد ودوره

يحصر كل مورد وكيانه وخدمته وأدواره ودول المعالجة والوصول والنسخ والجهات الفرعية وعقده وحالة اعتماده ومسار خروجه. يحدد عقد المعالج الغرض والفئات والمدة والتعليمات والضمانات والتعاون في الحقوق والإتلاف وإشعار جهة التحكم بالتسرب دون تأخر غير مبرر، والموافقات المنطبقة على المعالجين الفرعيين. ويثبت التحقق الدوري من التزامه، لا مجرد امتلاك شهادة تسويقية.[2]

فحص التدفق

تشمل الخريطة الاستضافة والبريد والرسائل والدعم والتحليلات وشبكات التوزيع والحماية والنسخ والتعافي والوصول البعيد والذكاء الاصطناعي. لا يفترض وجوب توطين جميع بيانات كل موقع خاص، ولا تكفي استضافة قاعدة محلية لنفي النقل. يثبت مسوغ المعالجة ومسار النقل الخارجي وشروطه وضماناته وتقويم مخاطره عند انطباقه؛ ولا تجعل الموافقة أو البنود التعاقدية وحدها بديلًا عن شروط المسار والقطاع.[1][3]

خروج قابل للإدارة

قبل اعتماد المورد يجب معرفة صيغة الاسترجاع وتكلفته وطريقة الإتلاف وإثباته وبديله؛ المورد غير القابل للخروج خطر يحتاج قرارًا لا إخفاءً.

08 الحسابات المؤسسية والهوية والصلاحيات

السيطرة المؤسسية مستقلة عن حساب الفرد، والامتياز محدود بالحاجة.

ملكية وإدارة الحسابات

يجب أن تكون حسابات النطاق والمستودع والاستضافة والخدمات والمتاجر والفوترة والتجديد والاسترداد تحت سيطرة المؤسسة أو كيان مصرح له. يستخدم الأشخاص حسابات فردية مسماة بدعوات وأدوار، ولا تشارك كلمات مرور حساباتهم الشخصية أو تسلم هوياتهم بوصفها أصولًا للشركة. يحصر سجل الأصول صاحب الحساب وحافظه وطريقة الاسترداد والبديل والقيود على نقله.

المصادقة والجلسة

تثبت الهوية من جلسة خادمية موثقة أو مزود هوية معتمد، ولا يعتمد على ترويسة مثل X-User-ID يرسلها العميل لإثبات الفاعل. تعتمد مصادقة متعددة العوامل للحسابات الحساسة، وتحقق متدرج للأفعال الحساسة مثل إدارة الامتيازات والتصدير وتغيير جهة التشغيل، دون إعادة تحقق عامة لكل تنقل. يحمى الاسترداد بنفس عناية الدخول، ولا يختار الدعم كلمة مرور المستخدم.

تجدد الجلسات عند تغير الامتياز، وتبطل خادميًا عند الخروج أو التعطيل أو السحب، مع معالجة رموز الوصول والتحديث وتفويضات المزود كل بحسب نوعه. تضبط مددها وفق الخطر، وتحفظ كلمات المرور باشتقاق آمن

مملح باستخدام مكونات موثوقة. تحمى ملفات الجلسة وإعداداتها، ولا يعد حذف ملف الارتباط وحده إبطالًا لجميع وسائل الوصول.

أقل صلاحية واسترداد مضبوط

تقيد صلاحيات البشر وهويات الخدمة بالفعل والمورد والبيئة والأجل والغرض. يفصل الكاتب عن القارئ والحافظ والمعتمد حيث تقتضي الحساسية، ويحدد الوصول الطارئ بسبب ومدة ومراقبة ومراجعة. توثق تهيئة أول مشرف بدعوة محدودة ومستقلة، وطريقة التعافي عند فقد الخدمة أو المسؤول، بلا حساب خفي أو مفتاح رئيسي دائم للمطور.

> **سلطة مقيدة**
>
> المالك والمشرف الرئيسي يملكان قرارات محددة، لا تصريحًا دائمًا لقراءة جميع البيانات الشخصية؛ كل وصول يحتاج وظيفة وغرضًا وتفويضًا.

09 الإنفاذ الخادمي وواجهات التكامل والملفات

الثقة تُبنى في الخادم، ولا يمنح إخفاء الزر حماية للكائن.

تفويض متعدد المستويات

يجب التحقق خادميًا من الفعل والكائن والحقل والمستأجر في كل مسار، بما فيه البحث والتنزيل والتصدير والعامل الخلفي. يستمد نطاق الجهة من هوية وعضوية موثقتين، لا من معرف يرسله العميل وحده. تعتمد قوائم سماح منفصلة لحقول القراءة والكتابة، ولا يعاد صف داخلي كامل ليخفي المتصفح أجزاءه، ولا يسمح تعديل الملف الشخصي بتغيير الدور أو المالك.

يوثق لكل واجهة API مخطط المدخل والرد والمصادقة ونطاق المورد والغرض والأثر الجانبي وحدود المعدل والحجم والمهلة. تفرض حصص متناسبة بالفعل والحساب والجهة، وتمنع المعاملات والقيود الموثوقة تكرار الدفع أو الإرسال عند إعادة الطلب. تعاد مراجعة الصلاحية والموافقة وحالة المورد عند تنفيذ مهمة مؤجلة، لا عند إدراجها فقط.

مدخلات واتصالات آمنة

يتحقق الخادم من الأنواع والأحجام والقيم، وتستخدم استعلامات معلمة وترميز مخرجات بحسب السياق وتنقية المحتوى المسموح. تحمى تغييرات الحالة من تزوير الطلبات CSRF، وتعتمد TLS والتحقق من الشهادات وسياسة محتوى CSP مناسبة للميزات. لا يفرض رأس أمني مطلق يعطل تضمينًا أو وظيفة مشروعة دون تقييم، ولا يعد CORS تفويضًا للمستخدم.

الملفات والتكاملات

تفحص الملفات بالنوع الفعلي والحجم وحدود فك الضغط، وتحجر وتفحص بمكافحة برمجيات خبيثة متناسبة قبل الإتاحة، وتمنع قابليتها للتنفيذ. يستخدم تنزيل مفوض أو رابط موقع محدود المدة والنطاق. تفحص وجهات الجلب والتحويلات والشبكات غير المأذونة، وتتحقق إشعارات المورد وتوقيعاتها وحالة الطلب من المصدر الموثوق، مع رسائل فشل مفهومة لا تكشف تفاصيل خاصة.

> **حد الثقة**
>
> نجاح المصادقة لا يثبت حق الفعل، ونجاح التفويض لا ينشئ مسوغ معالجة؛ يجب استيفاء الاثنين دون تحميل المستخدم تفاصيل الإنفاذ.

10 سجل الإجراءات والتدقيق ومقاومة العبث

أصل الحدث ثابت أثناء الاحتفاظ، والتصويب أثر جديد قابل للتتبع.

سجل للقراءة فقط

يجب أن تعرض لوحة المشرف الرئيسي سجل إجراءات وتدقيق للقراءة فقط، غير قابل للتعديل أو الحذف اليدوي من أي مستخدم أو مشرف أو مطور أثناء مدة الاحتفاظ. يطبق تخزين إلحاقي أو WORM أو ضمان مكافئ مثبت من مصدر التقنية، مع فصل صلاحيات الكاتب والقارئ وحافظ التخزين، وقفل احتفاظ لا يستطيع مسؤول التطبيق تجاوزه.

تثبت مقاومة العبث وكشفه بتوثيق حدود الثقة وإعدادات المصدر ودليل مستقل، مثل تحقق سلامة محمي خارج مسار الكتابة. لا يدعى استحالة التغيير بيد مالك سحابة يملك صلاحيات خارج تلك الحدود. يصحح خطأ الحدث بإلحاق حدث تصويب يربط بالأصل وسببه ومعتمده، دون تعديل الأصل. ينفذ الإتلاف الدوري بعد انتهاء الغرض والمدة، مع تحفظ مشروع مضبوط ومراجعته، لا احتفاظ أبدي.

محتوى الحدث

يسجل الحدث بحسب أهميته الدخول ونتيجته والأدوار وعرض البيانات الحساسة أو تصديرها والموافقات والحقوق وتغيير المالك والاستنساخ والنقل والعمل الفني والإعدادات والإطلاق والنسخ والإتلاف والحوادث. تستند نسبته إلى هوية خادمية موثقة، ويشمل مرجع الفاعل ودوره وجهته ونطاقه والفعل والكائن والنتيجة والسبب عند صلته، والوقت ومعرف الترابط وإصدار السياسة أو القرار؛ دون أسرار أو أجسام حساسة خام.[5]

ضمان الحفظ

يرتبط الفعل الحرج وحدثه بمعاملة وصندوق أحداث دائم، أو فشل آمن أو صندوق موثوق مع إعادة محاولة وضبط التكرار، بما يثبت عدم اعتماد أثر حرج بلا أثر تدقيق محفوظ. لا تكفي مهمة مؤقتة بعد الاستجابة لإثبات التسليم. يمكن تنفيذ أحداث غير حرجة خلفيًا مع رصد فقدها وإنذار وإصلاح؛ وتحدد سياسة التصنيف ما هو حرج بدل تسجيل كل نقرة بالتكلفة نفسها.

الدليل الأدنى

السجل يثبت تسلسلًا قابلًا للفحص ضمن حدوده؛ لا يصبح دليلًا قاطعًا بمجرد التوقيع أو الوقت، ولا يغني عن إشعار صحيح أو قرار مشروع.

11 قراءة السجلات والتصدير المأذون

زر واضح، ونطاق قليل، ونسخة يمكن التحقق منها.

عرض بحسب المهمة

يرى كل شخص فقط ما يلزم وظيفته؛ فلا تمنح شاشة المشرف الرئيسي صلاحية مطلقة للبيانات الشخصية. تفصل إدارة الأدوار عن الاطلاع الحساس، وتقلل حقول العرض وتحجب المعرفات عند كفاية المرجع. تتيح اللوحة بحثًا مفهومًا بحسب الحدث والنطاق والمدة والنتيجة، وتوضح سبب القيود بدل إغراق المشرف بتفاصيل لا يحتاجها.

تصدير بسيط ومحدد

يجب توفير زر تصدير بسيط ضمن الصلاحية، يحدد نطاق الجهة والمدة والفئة ومستوى التقليل والصيغة. تستخدم CSV أو JSON للمعالجة، وPDF آمن ومقروء عند الحاجة إلى نسخة مفهومة، مع شرح الحقول والحدود. تنقح البيانات قبل إنشاء الملف، وتعالج حقول CSV التي قد تفسر كصيغ مخادعة، فلا يصبح فتح التقرير قناة لتنفيذ أو تسريب.

تربط النسخة بوقت إنشائها وإصدار مخططها ومعرفها، وتوفر توقيعًا أو تجزئة للتحقق من سلامتها في قناة موثوقة. يسلم الملف عبر رابط مؤقت أو قناة محمية، ويبلغ طالب التصدير باكتماله، ويسجل الطلب

والقرار والتنفيذ والتنزيل عند إمكان رصده. تحدد مدة الملف وإتلافه، وتراجع الصلاحية مجددًا عند التنفيذ المؤجل، ولا يرسل مرفق شامل إلى بريد غير متحقق منه.

طلبات الجهات المعنية

يوثق طلب الجهة وصفة طالبه وسنده ونطاقه قبل الإفصاح، ويفحص المراجع المختص ما يسمح بتقديمه أو يجب حجبه. تسلم أقل مادة لازمة بصيغة مفهومة، دون كشف بيانات الغير أو جميع السجلات لمجرد توفر زر تنزيل. تحفظ نسخة الطلب والقرار وأثر التسليم وفق الاحتفاظ المنطبق، وتبقى ملفات الحوادث والأدلة الحساسة بعيدة عن العرض العام.[2][1]

> **الميسر الآمن**
>
> سهولة التصدير تعني تقليل الجهد المأذون، لا توسيع صلاحية طالب الملف أو إلغاء التنقيح والاحتفاظ.

12 البيئات والإصدارات والصيانة وجودة التنفيذ

كل تغيير له نطاق محفوظ ودليل رجوع، ولا يعتمد الإنتاج على جهاز شخص.

فصل التشغيل والتطوير

يجب فصل الإنتاج والتطوير والاختبار والتعافي، بما يشمل الحسابات وقواعد البيانات والملفات والأسرار. يستخدم الفني بيانات اصطناعية لا بيانات الإنتاج افتراضيًا؛ وأي وصول استثنائي للإنتاج يكون بحاجة موثقة وأقل امتياز ومدة واعتماد وسجل. تحفظ الأسرار في خزنة مخصصة، ولا تدرج في المصدر أو المتصفح أو آثار البناء أو تذاكر الدعم.

سلسلة إصدار محكومة

تراجع تغييرات الكود والإعدادات، وتحكم صلاحيات الدمج والنشر CI/CD بهويات خدمة مؤسسية. تحفظ إصدارات التبعيات وقائمة مكونات البرمجيات SBOM وتراخيصها ونتائج فحص الأسرار والكود والثغرات ومنطق الأعمال. يرتبط القبول بإصدار محدد وبيئة ونطاق، لا بشارة نجاح عامة، وتحدد مسؤولية متابعة التصحيحات الأمنية والتبعيات والتجديدات والسياسات.

قبل الانتقال أو الترحيل أو تغيير المورد تحفظ نقطة استعادة للكود والإعدادات والقرارات وحالة المخطط والبيانات المحمية عند الحاجة. تختار ترحيلات متوافقة وخطة رجوع تشمل المخطط والملفات والمهام والمورد، لا إرجاع الكود وحده. لا يعيد الرجوع غرضًا مسحوبًا أو صلاحية ملغاة أو بيانات مستحقة الإتلاف؛ وتفصل هذه القرارات عن إصدار الواجهة.

دليل جودة متناسب

تحدد اختبارات الوحدات والتكامل والانحدار والأداء والأمن والرحلات بحسب الخطر. توثق النتائج الفعلية وأوجه الفشل وحدود القياس والمسؤول والإصلاح وتاريخ المراجعة، وتستند أهداف الأداء إلى خط أساس وعقود وحاجة المنتج، لا أرقام نظامية مختلقة. الاستقلال والصيانة المنظمة يقللان الارتهان والتكلفة، ولا يعنيان غياب التحديث أو الحاجة إلى مختص.

> **تغيير موضعي**
>
> يجب تحديد ما سيتغير وما يجب ألا يتأثر، وحفظه وفحصه؛ لا تستخدم المواءمة تصريحًا لإعادة بناء وظائف سليمة خارج النطاق.

13 الحوادث والتسرب وقرارات الإخطار

التنبيه بداية تقييم، والعلم نقطة زمنية موثقة لا يعاد تأريخها.

تصنيف وأوقات منفصلة

يجب حفظ خط أساس للمراقبة وفتح سجل للحادث يميز الحادث السيبراني وتسرب البيانات والتوقف. ليس كل تنبيه أو فشل دخول تسربًا؛ وقد يكون الإفصاح بالخطأ أو الوصول الداخلي غير المأذون أو التلف تسربًا دون نشر عام. تسجل أوقات الوقوع المعروف أو المقدر والتنبيه والعلم وأساسه والإجراءات، وتفصل الوقائع عن التقديرات، ويعاد القرار عند معلومات جديدة.[2]

إخطار الجهة وصاحب البيانات

عند تحقق شرط المادة 24/1، تشعر جهة التحكم الجهة المختصة خلال مدة لا تتجاوز اثنتين وسبعين ساعة من العلم بالحادثة إذا كان من شأنها الإضرار بالبيانات أو صاحبها أو التعارض مع حقوقه أو مصالحه. لا ينتظر اكتمال التحقيق لإعادة بدء المهلة. يرسل بلاغ أولي بالمعلوم وتوسم تقديراته، ويستكمل غير المتاح في أقرب وقت مع مبررات التأخر وفق النص.[2]

يشعر صاحب البيانات دون تأخير غير مبرر عند شرط المادة 24/5، باحتمال الضرر ببياناته أو التعارض مع حقوقه أو مصالحه؛ ولا تعمم عليه مهلة اثنتين وسبعين ساعة. يكون الإخطار واضحًا في الواقعة والمخاطر والتدابير والتواصل والنصيحة المناسبة، دون طلب كلمة مرور أو رمز تحقق. تحفظ البلاغات والتحديثات ودليل إرسالها في ملف محدود الوصول.[2]

التزامات متعددة ومسؤول بديل

تراجع الواجبات الأخرى بحسب القطاع والتجارة والضوابط المنطبقة والعقود، وتدار ساعة مستقلة لكل مستلم وعتبة. يشعر المعالج جهة التحكم دون تأخر غير مبرر، وفق اللائحة والعقد، لا بعد استنفاد مهلة المتحكم. يحدد قائد الحادث والمفوض بالإبلاغ والبديل والقناة الرسمية ومصدر الساعة وإثبات المحاولة؛ وتعطل القناة لا يفترض أنه يعلق المهلة.[2]

إفصاح مضبوط

لا تعرض الحوادث للجمهور في لوحة عامة؛ تصل المعلومات اللازمة للمخولين والمتأثرين والجهات المستحقة دون تهوين أو اتهام غير مثبت.

14 الاحتواء والتعافي والنسخ والاستمرارية

الاستعادة تعيد خدمة سليمة وحقوقًا نافذة، لا مجرد صفحة تعمل.

احتواء متناسب

يجب أن يملك المناوب إجراءً لتصعيد الحادث وحفظ الأدلة المعرضة للضياع وعزل المسار أو الهوية المتضررة وإبطال الجلسات أو التكاملات المعنية. تحافظ الخدمة على الوظائف المشروعة حيث أمكن، عبر وضع تشغيل محدود وآمن، ولا يستخدم حجب عام تلقائي لعقاب المستخدمين. تسير أعمال التحقيق والإخطار والاحتواء بالتوازي، مع تسجيل الأسباب والمسؤولين والأوقات.

تحفظ سلسلة حيازة الأدلة بمصدر ووقت ونقل وصلاحية وسلامة، ويمنع نسخ الأسرار والبيانات الخام إلى تذاكر عامة. يعالج السر المكشوف عند مصدره، وتراجع طرق استخدامه والامتيازات التي يفتحها، ويثبت رفض قيمته القديمة. لا يتلف مفتاح تشفير مطلوب لنسخ مشروعة دون خطة إعادة تشفير أو استعادة؛ مفتاح فك البيانات يختلف عن رمز دخول خدمة.

تعافٍ معزول ومختبر

تعتمد نسخ مشفرة ومعزولة وفق الخطر، مع فصل إدارة النسخ ومفاتيحها عن مسار الإنتاج المعرض للضرر. تستعاد إلى بيئة معزولة من مصدر نظيف، وتفحص المعاملات والملفات والصلاحيات والتبعيات،

وتطبق أحدث قرارات الحذف والتصحيح والسحب قبل فتح الحركة تدريجيًا. يحدد المالك مقدار فقد البيانات المقبول RPO وهدف زمن الاستعادة RTO بحسب أثر الخدمة والعقد والقطاع، دون قيم إلزامية مختلقة.

إغلاق وتحسين

يقبل صاحب الخدمة تقرير التعافي وسلامته وفجواته ومراقبة التكرار، وتستمر تحديثات البلاغات عند الحاجة. يوثق السبب الجذري والإصلاحات ومسؤولها ودليل التحقق منها، وتراجع ضوابط المورد والاسترداد والمناوبة. يجب إجراء تمارين واستعادة واختبارات مناسبة وتسجيل نتائجها عند التنفيذ؛ لا يوصف الإجراء المقترح في هذا المرجع بأنه تجربة ناجحة أو اختبار لمنصة بعينها.

القبول العملي

نجاح النسخ لا يثبت نجاح الاستعادة، وعودة الخدمة لا تنفي التسرب؛ لكل نتيجة دليل مستقل وقرار مسؤول.

15 التجارة والمدفوعات والفوترة والخصائص المنظمة

العرض والتكلفة والحقوق جزء من الخدمة، والتصنيف يسبق التحصيل.

عقد وتكلفة واضحان

عند انطباق التجارة الإلكترونية يجب بيان مقدم الخدمة وصفته وهويته وتواصله، وخصائص المنتج أو الخدمة والسعر الإجمالي والرسوم والضرائب والتسليم والتنفيذ والضمان، قبل الالتزام. توضح الخطوة التي تنشئ العقد وترتب الدفع، ويتيح المسار مراجعة البيانات وتصحيحها، ويحفظ العرض والشروط والإيصال وقت التعاقد. لا تسمى رسالة استلام الطلب عقدًا مؤكدًا إذا لم تكن كذلك.[14]

تبين الاشتراكات قيمة الدفعات ودوريتها والتجديد والخصم التالي والإلغاء وآثاره، دون رسوم مخفية أو اختيار مضلل. تصاغ سياسة الإلغاء والاسترجاع بحسب الفئات والحقوق النظامية والاستثناءات المنطبقة، ولا يعتمد حظر عام للاسترجاع أو رصيد متجر بدل رد واجب. تتاح الشكاوى والضمان وتصحيح الطلب بوسيلة بسيطة، ولا تستخدم صفة الوسيط لنفي دور فعلي.[14]

دفع لدى مقدم مأذون

يستخدم مقدم مدفوعات مرخص في النطاق المناسب، مع التحقق من كيان المزود ونوع خدمته. يفضل الدفع المستضاف أو حقول المزود لتجنب حفظ رقم البطاقة الكامل، ويحظر حفظ رمز التحقق CVV في المنتج أو السجلات. يحتفظ بأقل مرجع عملية وفاتورة لازم، ويتحقق الخادم من المبلغ والعملة والطلب والإشعار الموثوق ومنع التكرار والرد، لا من رجوع المتصفح وحده.[16]

بوابة القطاع والضريبة

تفحص الفوترة والضريبة بحسب صفة المنشأة والتوريد ومرحلة الربط المطبقة عليها، وتستخدم متطلبات زاتكا في نطاقها، دون جعل كل إيصال فاتورة ضريبية أو كل موقع خاضعًا للربط. تحفظ الفواتير التاريخية وتصحح بالإجراءات المنطبقة لا بتغيير الهوية الحالية.[15] وتتوقف وظائف المحافظ والتحويل والاستثمار والصحة والعقار والتعليم أو الخدمات الحكومية المنظمة حتى التصنيف واستكمال الترخيص أو الموافقة المطلوبة، مع منع التنفيذ الخادمي للوظيفة المعلقة.

تسهيل دون إخفاء

اجمع بيان التكلفة والالتزام والحقوق في لحظة القرار؛ لا تحول الامتثال إلى شاشة مطولة، ولا تخفِ معلومة جوهرية لتقصير الرحلة.

16 حقوق المصنفات والمحتوى والذكاء الاصطناعي

الحق مصدره سند واضح، والأداة لا تمنح ترخيصًا تلقائيًا.

سند الحقوق والتراخيص

يجب توثيق مصدر الكود والتصاميم والعلامات والخطوط والصور والمحتوى والإصدارات وأصحاب الحقوق والتراخيص والقيود. يشترط عقد مكتوب صريح يحدد المخرجات والحقوق المالية المنقولة أو المرخصة ومدتها ونطاقها وحقوق التعديل والبناء وإعادة الاستخدام والاستنساخ والتوزيع والتنازل بحسب الاتفاق الصحيح، مع تمييز مكونات الغير وأدوات المقاول السابقة. لا تكفي حيازة المستودع أو ترويسة الملكية أو دفع الفاتورة لإثبات جميع الحقوق.[13]

تراجع تراخيص المصدر المفتوح والتبعيات التجارية وشروط النسبة والتوزيع والإتاحة، دون افتراض أن جميع المكتبات تفرض نشر كامل المنتج. تفصل ملكية المصنف عن العلامة والنطاق والعقود وحسابات الخدمات، وتحفظ الحقوق الأدبية التي لا يجوز إسقاطها. لا يوضع شعار جهة أو شارة اعتماد أو شراكة غير مأذونة لإكمال المظهر المؤسسي.[13]

محتوى المستخدم والبلاغ

عند قبول محتوى المستخدم يحدد ترخيص محدود بالاستضافة والعرض والتحويل اللازم، ولا يستنتج منه حق التدريب أو الإعلان. تتاح قناة بلاغ ومراجعة واعتراض، وإجراء متناسب لتعطيل المحتوى ومشتقاته عند الانطباق، مع حفظ دليل محدود وصون حقوق الأطراف. لا يعد كل بلاغ مخالفة ثابتة، ولا تمنح شروط الاستخدام حصانة عامة عن مسؤوليات المنصة.

ذكاء اصطناعي معتمد الغرض

لا يفعل الذكاء الاصطناعي الخارجي افتراضيًا. عند اعتماده يحصر الغرض والبيانات والمورد والتخزين والتدريب والمراجعة البشرية والدول والمدة والإيقاف، وتقلل المدخلات وتحجب الأسرار. يوضح للمستخدم دوره وحدود مخرجاته وتتاح قناة بشرية مناسبة. تنفذ صلاحية الأدوات خارج النموذج، وتعامل المستندات والمخرجات كمدخلات غير موثوقة؛ ولا يجيز التنويه خدمة منظمة بلا إذن أو حقوقًا حصرية مضمونة للمخرجات.[1][2]

استعمال مأذون

المحتوى المتاح أو الناتج آليًا ليس خاليًا تلقائيًا من حقوق الأشخاص والغير؛ يعتمد الاستخدام بعد فحص الغرض والسند والبيانات.

17 الهوية المرنة والاستنساخ المستقل

النواة قابلة لإعادة التهيئة، والنسخة الجديدة مستقلة وفارغة افتراضيًا.

إعدادات منفصلة عن النواة

يجب فصل منطق الأعمال عن الهوية التجارية والجهة القانونية والخصوصية والتشغيل والبنية والتوزيع في المتاجر. تستخدم إعدادات ذات مخطط تحقق وقوائم سماح وأنواع ومراجع وإصدارات وتاريخ نفاذ وسجل تغييرات واعتماد. لا يسمح تعديل كائن تهيئة كامل بتغيير جهة التحكم أو المشرف أو مفاتيح الدفع دون مسار خاص، ولا تشتق جهة التحكم تلقائيًا من مالك الأصل.

- الهوية: الاسم العربي والإنجليزي والشعار والألوان والخطوط والنطاق واللغة والروابط وقنوات التواصل.
- الجهات والسياسات: مالك الأصل وصاحب الحقوق والمشغل وجهة التحكم والمشرف الجديد وإصدارات الشروط والخصوصية والاحتفاظ.
- الموارد: معرف منصة ومستأجر فريد، وقاعدة وملفات وحاويات تخزين وبحث وطوابير ونسخ وهويات خدمة ومراجع أسرار مستقلة أو فصل مثبت.
- التكاملات والتوزيع: تسجيلات OAuth وعناوين العودة والبريد والدفع والإشعارات ومعرفات المتاجر والتوقيع والأصول الأمنية عند وجودها.

نسخة فارغة

تبدأ النسخة الجديدة بمخطط وبيانات اصطناعية أو محتوى عام مرخص فقط، دون العملاء أو الحسابات أو الموافقات أو سجل تدقيق الأصل أو الأسرار أو الجلسات أو الرموز أو الاشتراكات الخاصة. تنشأ دعوة مشرف جديد وقنوات اتصال جديدة، ولا تورث بيانات المالك والمشغل السابقين بوصفها إعدادات افتراضية. تبقى التكاملات الخارجية معطلة أو في اختبار إلى اعتمادها.

قبول النسخة

يثبت اختبار الفصل عدم وصول النسخة إلى موارد الأصل عبر الواجهات والملفات والبحث والذاكرة المؤقتة والمهام والنسخ. تفحص الهوية في الناتج والبريد والإشعارات والوثائق والروابط لا في الصفحة الأولى فقط. المتغيرات تسهل التهيئة، لكنها لا تنشئ حقوق النسخ أو جميع الموارد أو قبول المتاجر؛ وتراجع سياسة التطبيقات القالبية لدى Apple، ومنها البند 4.2.6، بحسب التجربة ومقدم المحتوى.[11]

حد الاستنساخ

الاستنساخ المستقل ليس نقل خدمة بحساباتها؛ أي إدخال لبيانات حقيقية يحتاج خطة نقل ومسوغات واعتمادات منفصلة.

18 البيع والهبة ونقل الملكية أو التشغيل

تنتقل الحقوق والأصول بحسب سندها، والبيانات ليست ملحقًا مباعًا تلقائيًا.

تعريف التصرف والجهات

يبدأ الانتقال بقرار يميز بيع الحصص مع استمرار الشخصية الاعتبارية عن بيع أصول المنصة، والهبة أو التنازل، وتغيير المشغل دون تغيير المالك، ونقل الاستضافة. يحدد مالك كل أصل وصاحب الحقوق وجهة التحكم والمعالج والمشغل والمشرف قبل النفاذ وبعده. تغيير المساهم أو حقل المالك لا يغير بذاته جهة التحكم أو جميع العقود.

حزمة منفصلة لكل فئة

يفصل سجل الانتقال الكود والمصنف والعلامة والتراخيص والعقود والنطاق وحسابات السحابة والموردين والدفع والمتاجر والبيانات. يراجع سند كل حق وقابليته للتصرف، وموافقة الأطراف وشروط المورد ومسجل النطاق والقطاع والمتجر عند اللزوم. لا تعد مشاركة كلمة مرور حساب شخصي نقلًا مؤسسيًا، ولا يمنح نجاح أداة ترحيل إذنًا بعقد أو أصل غير قابل للنقل.

تفحص جهة المغادرة مسوغ الإفصاح، والمستقبلة مسوغ الجمع والمعالجة، والأغراض والإشعارات والاحتفاظ والنقل الخارجي. لا يجيز عقد بيع الأصل نقل جميع بيانات العملاء، ولا تفسر موافقة تسويق قديمة تصريحًا لمنتج مستقل. تستخدم العناية الأولية بيانات اصطناعية أو مواد منقحة، ويعتمد أي اطلاع ضروري على بيانات حقيقية قبل إتاحته.[1][2][3]

مراحل وإغلاق

يعتمد الجرد والحقوق وخطة المخاطر والرجوع، ثم تحقق معزول واستكمال الموافقات الخارجية، ثم موارد وأسرار وبناء ونشر وترحيل مسموح وقبول، ثم سحب طرق الوصول السابقة فعليًا. تحفظ نقطة استعادة ومحضر لكل مرحلة، وتستمر طلبات الحقوق بتوقيتها، وتصان العقود والفواتير والموافقات التاريخية. لا توصف العملية مكتملة قبل قبول التشغيل والالتزامات المنطبقة، ولا يفترض إنجاز فوري كامل لكل مورد أو جهاز.

نفاذ لا إعادة كتابة

حدث الانتقال يحدد ما بدأ وما بقي؛ الهوية الجديدة لا تمحو التزامات الماضي أو تعيد نسبة وثائقه إلى جهة أخرى.

19 عزل الفني واستقلال التشغيل وحزمة التسليم

قابلية استبدال الفريق تثبت بالمصدر والوثائق وإبطال طرق الوصول.

جرد وسائل الوصول

يجب حصر العضويات والجلسات ومفاتيح SSH والنشر والرموز وهويات الخدمة وصلاحيات CI/CD وتطبيقات OAuth والتكاملات وwebhooks والبريد والنطاق وDNS والنسخ ووسائل الاسترداد. حذف العضوية وحده غير كافٍ؛ يؤكد GitHub أن مفتاح النشر المرتبط بالمستودع قد يبقى فعالًا بعد إزالة منشئه، ولذلك يراجع ويعطل مستقلًا.[6]

سحب آمن مثبت

تنقل الوظائف الدائمة من هويات الفرد إلى هويات مؤسسية معتمدة، ثم تبطل الجلسات والمفاتيح والتفويضات المعنية، وتدور الأسرار التي اطلع عليها، ويثبت رفض الطرق القديمة. تراجع التغييرات الأخيرة والأبواب الخلفية والوجهات الخارجية، دون تعطيل خدمات مشروعة أو إتلاف مفاتيح فك تشفير لازمة لاستعادة مشروعة. لا يدعى محو نسخ سبق تنزيلها خارج حدود سيطرة المؤسسة؛ تعالج الالتزامات والتحقيق بحسب الحالة.

تسليم يمكن إعادة بنائه

تضم الحزمة المصدر وتاريخ الإصدارات والتصاميم ومخطط البيانات وقاموسها وواجهات API والبنية ووصف التهيئة والبنية ككود عند استخدامها، وأدوات البناء والتبعيات والتراخيص وسجل الأصول والموردين والتجديدات. تسلم مراجع الأسرار عبر قنوات آمنة، وأدلة النشر والمراقبة والاسترداد والنسخ والاستعادة والتراجع والحوادث المسموح بها والمهام المفتوحة وقنوات المختصين، دون نسخ جماعي غير لازم لبيانات الأشخاص.

يعاد البناء والنشر والاستعادة بواسطة فريق بديل لم يشارك في الإنشاء، من المصدر والوثائق دون جهاز الفني السابق أو حسابه. يوثق الاختبار ونسخته وبيئته ونتائجه وحدوده، وتفحص محاولات الدخول السابقة واستمرار هويات الخدمة المأذونة. لا يثبت الاستقلال بتسليم ملف تنفيذي أو عبارة جاهزية، ولا يتحول استبدال الفني إلى إلغاء واجب الصيانة.

> **استقلال قابل للاستلام**
>
> لا تعتمد الحزمة حتى يستطيع البديل فهمها وتشغيلها في اختبار مأذون، وتغلق النواقص الحرجة أو يحدد نطاق منعها ومسؤول علاجها.

20 الموقع والويب والتطبيق التقدمي

تزداد الضوابط بزيادة الوظائف، لا بمجرد تغيير اسم المنتج.

موقع بحد مناسب

قد تكفي للموقع التعريفي ملفات ومحتوى وأصول مرخصة ونطاق واتصال HTTPS وتحكم آمن في النشر ونسخة ودليل استعادة. لا يفرض حساب زائر أو قاعدة عملاء. عند نموذج التواصل تعتمد أقل حقول ووجهة استلام وإشعار وحماية خادمية وحدود إساءة وفشل مفهوم، ويثبت وصول الطلب. تشمل الخصوصية سجلات الاستضافة والخدمات حتى بلا نموذج، ولا تخفى الإفصاحات اللازمة خلف لوحة الإدارة.

ويب تفاعلي

عند الحسابات والمعاملات يضاف سياق جلسة موثق وتفويض خادمي وواجهات مقيدة وسجل تدقيق ودورة حقوق واحتفاظ ومهام وترحيلات ونسخ. تبقى الموارد العامة متاحة دون حساب بحسب غرضها. يختبر رفض تبديل الكائن أو الجهة أو الحقل، والجلسة والدور الملغيين، مع نجاح المسارات المأذونة. لا يفترض إطار تقني أو منتج قاعدة بيانات أو تطبيق جوال بعينه.

PWA بحسب الميزة

تعتمد قابلية التثبيت وفق manifest صحيح واتصال آمن ودعم المتصفحات والأجهزة المستهدفة. عامل الخدمة ليس شرطًا عامًا لقابلية التثبيت بذاتها؛ يستخدم عند حاجة إلى العمل دون اتصال أو التخزين أو ميزة تدعمه، ويظل استخدام الويب بديلًا عند تعذر التثبيت.[7] لا توضع معرفات المستخدم أو الرموز في نقطة الإطلاق أو إعدادات عامة.

يقتصر التخزين الافتراضي على الأصول العامة، وتستبعد الردود الخاصة والحسابات والمرفقات من قواعد التخزين المؤقت. ينظف الخروج بيانات الحساب محليًا ويبطل الجلسة خادميًا، وتعاد مراجعة صلاحية الطلب المؤجل عند الاتصال. توثق دورة تحديث العامل ونسخ التخزين والتوافق وحفظ العمل غير المرسل، وتختبر التبويبات والعملاء القدامى. لا يعد المتصفح نسخة احتياطية، ولا يضمن الإبطال مسح جهاز غير متصل أو ملف خرج عن السيطرة.

قبول بحسب النوع

يجب اختبار الموقع بحدوده، والويب بوظائفه، وPWA بتثبيته وتخزينه وتحديثه إن وجدت؛ نجاح أحدها لا يثبت قبول الآخر.

21 الجوال والتوزيع والأذونات ونقل التطبيق

هوية المتجر والتوقيع والخدمات المرتبطة مسارات مستقلة عن الويب.

حساب وهوية وتوزيع

يجب أن تسيطر المؤسسة أو الكيان المصرح على حسابات التوزيع وتفويضات الفريق، ومعرفات التطبيقات والتوقيع والتجديد وقنوات الاختبار والإصدار. تفحص النسخة الموزعة الفعلية والروابط العميقة والتسجيلات والوجهات والتخزين الآمن، وتطابق إفصاحات المتجر مع SDKs وبياناتها ومورديها. لا يزيل الغلاف الهجين التزامات الجوال أو يجعل قبول الويب قبولًا للمتجر.

إذن وحقوق دون عائق زائد

تطلب قدرات الكاميرا والموقع والإشعارات عند استخدامها وبأقل إذن، مع شرح وبديل مناسب عند الرفض؛ وإذن النظام ليس مسوغ معالجة مستقلًا. تحمى الرموز والمفاتيح بأدوات التخزين الآمن المناسبة، وتقلل بيانات شاشة القفل. عند دعم إنشاء الحساب، تتيح Apple بدء الحذف داخل التطبيق، ولا تشترط عمومًا حذفًا فوريًا وآليًا. وتطبق متطلبات Google للمسار الداخلي ورابط الويب لطلب الحذف في نطاقها، مع بيان المدة والاحتفاظ المشروع.[8][9]

نقل وتحديث متوافق

تفحص أهلية نقل التطبيق لدى المتجر، ومعرفاته وخدماته وتوقيعه وصلاحياته. لدى Apple لا ينتقل معرف تاجر Apple Pay تلقائيًا مع التطبيق، وتحتاج آثار Keychain وAPNs وتسجيل الدخول والخدمات المستخدمة إلى خطة معالجة؛ ولدى Google لا تنتقل جميع إعدادات الربط والأذونات والتقارير. يعاد الربط وتختبر أول نسخة بعد النقل، ولا يمنح مسار المتجر مسوغًا سعوديًا شاملًا لنقل بيانات المنصة.[10][12]

تحدد خطة الإصدارات توافق الخادم وترحيل البيانات المحلية والعملاء القدامى والتحديث الفاشل والإصلاح الطارئ. لا يفترض تنزيل التحديث فورًا أو الرجوع القسري لكل جهاز أو مسح إصدار عن بعد. تراجع المشتريات الرقمية ووسيلة الدفع وسياسات التتبع والمتجر بحسب المنتج والسوق، وتراجع النسخة المستنسخة المميزة وفق سياسات القوالب، لا بمجرد شعار جديد.[11]

قبول من مسارين

يلزم قبول هندسي ونظامي داخلي، وقبول متجر عند توزيع يتطلبه؛ موافقة أحدهما لا تقوم مقام الآخر.

22 بوابات القبول والمواءمة والاستفادة والتصويب

لا يكتمل قرار الإطلاق أو الانتقال دون دليل منطبق وصاحب متابعة.

قبل الإطلاق والنقل

يجب جمع قرار النطاق والمسوغات والحقوق والموردين والسياسات والصلاحيات والاحتفاظ وخطة الحوادث وأدلة الإصدار والرحلات في ملف قبول متناسب. لكل اختبار إصدار وبيئة ومدخل اصطناعي ونتيجة متوقعة، ثم نتيجة فعلية ودليل عند تنفيذه. يمنع الإطلاق في نطاق غياب ترخيص أو مسوغ أو سند حقوق أو موافقة لازمة، أو تسرب أو سر مكشوف أو تعذر استعادة أو فصل مطلوب؛ ولا تعطل خدمة عامة سليمة بلا سبب.

- قبول التجربة: خطوات قصيرة وحقوق وتكلفة واضحة ورفض اختيار لا يمنع خدمة غير مرتبطة، مع العربية والإتاحة.
- قبول الحماية والبيانات: تفويض ورفض مثبتان، وتدقيق محفوظ وتصدير منقح وإتلاف لا تنقضه الاستعادة.
- قبول الاستقلال والانتقال: بناء وتشغيل بديل ونسخة مستقلة وحقوق وموافقات نافذة وإغلاق فعلي لوسائل الوصول السابقة.

مواءمة دون إضرار بما عداها

تبدأ مواءمة الموجود بحصر المشروع المأذون وقراءة خط أساس وتدفقات وصلاحيات، وحفظ نقطة استعادة، ثم تغيير محدد واختبار خاص ونشر تدريجي ومراقبة وخطة رجوع. تحفظ الوظائف والوثائق التاريخية خارج النطاق، وتحتوى المعالجة غير المشروعة أو الضرر المستمر دون استخدام التدرج لإدامته. يتضمن الإيقاف إخطارًا وحقوقًا وتسوية التزامات وإتلافًا واحتفاظًا مشروعًا بحسب النشاط، لا إغلاق واجهة وترك موارد مجهولة.

اعتماد صادق

يسجل المسؤول ما استوفى وما بقي وسبب المنع وصاحب العلاج؛ لا يكتب «مكتمل» لما ينتظر موافقة خارجية، ولا تنسب إلى هذا المرجع نتائج اختبار أو نقل أو شهادة لم تصدر.

الاستفادة والتصويب

نصيحة لمن يريد الاستفادة: طبّق هذا المرجع بقدر انطباقه على نشاطك وبياناتك ومورديك، وابدأ بأبسط خدمة صحيحة، ثم اربط قراراتك بمسؤول ودليل، واستعن بالمختص عند الحاجة. والتصويب أو التصحيح مرحب به؛ فالمراجعة المؤسسية تحفظ جودة المرجع وتواكب تغير الأنظمة والتقنيات، دون تحويل هدف العناية إلى ضمان مطلق.

الاستفسارات والتواصل

واتساب 0555444959

ceo@2030.sa.vision

التصويب مرحب به

واتساب 0566232776

rijalalwatan.com@gmail.com

مسار تحسين

يرسل التصويب محددًا بالموضع والمقترح ومصدره عند توفره؛ يراجع ويعتمد بإصدار جديد مع حفظ تاريخ التغيير.

23 المصادر المرجعية

المصادر النظامية تُطبق بحسب نطاقها؛ المعايير التقنية وسياسات المزودين تُراجع عند التنفيذ والتغيير.

[1] سدايا – نظام حماية البيانات الشخصية

النص المعدل؛ المواد 1 و4-8 و10-13 و15-19 و29 بحسب موضوع الإحالة.

https://dgp.sdaia.gov.sa/wps/portal/pdp/knowledgecenter/details/PDPL

[2] سدايا – اللائحة التنفيذية لنظام حماية البيانات الشخصية

المواد 1 و3-12 و15-20 و23-25 و32-33؛ حقوق وإشعار وموافقة ومعالجون وتقليل وحوادث وتقييم وسجلات.

https://dgp.sdaia.gov.sa/wps/portal/pdp/knowledgecenter/details/PDPL2

[3] سدايا – لائحة نقل البيانات الشخصية إلى خارج المملكة

الإصدار 2.0، أغسطس 2024؛ شروط ومسارات النقل والتقويم، مقروءة مع المادة 29 من النظام.

https://sdaia.gov.sa/Documents/RegulationonPersonalDataAR.pdf

[4] الهيئة الوطنية للأمن السيبراني – الضوابط الأساسية للأمن السيبراني

ECC-2:2024؛ قسم نطاق التطبيق، دون تعميم الإلزام على جميع الجهات الخاصة.

https://cdn.nca.gov.sa/api/files/public/upload/29a9e86a-595f-4af9-8db5-88715a458a14_ECC-2-2024---NCA.pdf

OWASP [5] – إرشادات تسجيل الأحداث

مصادر الأحداث وهوية الفاعل والسياق والنتيجة واستبعاد البيانات والأسرار غير اللازمة.

https://cheatsheetseries.owasp.org/cheatsheets/Logging_Cheat_Sheet.html

GitHub [6] – إدارة مفاتيح النشر

قسم عيوب مفاتيح النشر؛ استقلالها عن عضوية المنشئ وبقاء المفتاح بعد إزالته.

https://docs.github.com/v3/guides/managing-deploy-keys

MDN [7] – جعل تطبيقات الويب التقدمية قابلة للتثبيت

أقسام قابلية التثبيت manifestsودعم المتصفح؛ عامل الخدمة ليس شرطًا للتثبيت بذاته.

https://developer.mozilla.org/en-US/docs/Web/Progressive_web_apps/Guides/Making_PWAs_installable

Apple [8] – بدء حذف الحساب داخل التطبيق

إتاحة بدء الحذف للتطبيق الداعم لإنشاء حساب؛ وعدم وجوب الحذف الفوري والآلي عمومًا.

https://developer.apple.com/help/app-review/guideline-reference/5-1-1-account-deletion/

Google Play [9] – متطلبات حذف الحساب

مسار طلب الحذف داخل التطبيق ورابط الويب، في نطاق سياسة حذف الحساب.

https://support.google.com/googleplay/android-developer/answer/13327111?hl=en

Apple [10] – نظرة عامة على نقل التطبيق

آثار النقل على Apple Pay Keychaing وAPNsوالخدمات المرتبطة المستخدمة.

https://developer.apple.com/help/app-store-connect/transfer-an-app/overview-of-app-transfer/

Apple [11] – إرشادات مراجعة التطبيقات

البند 4.2.6 بشأن التطبيقات التجارية القالبية؛ وشروط مراجعة المنتج بحسب ميزاته.

https://developer.apple.com/app-store/review/guidelines/

Google Play [12] – نقل التطبيقات إلى حساب مطور آخر

نقل التطبيق والعناصر وإعدادات الأذونات والربط والتقارير التي لا تنتقل كلها تلقائيًا.

https://support.google.com/googleplay/android-developer/answer/6230247?hl=ar

[13] أم القرى – اللائحة التنفيذية لنظام حقوق المؤلف

نشر 31 يوليو 2026؛ المواد 20 و22 وأحكام التراخيص والحقوق؛ اشتراط سند مكتوب صريح للمخرجات والاستغلال.

https://www.uqn.gov.sa/decisions-and-regulations/4001498

[14] هيئة الخبراء – نظام التجارة الإلكترونية

المواد 6-8 و13-14؛ الإفصاح والعرض والفاتورة وحقوق الفسخ والتأخر بحسب شروطها.

https://laws.boe.gov.sa/BoeLaws/Laws/LawDetails/360de590-0286-4fa5-a243-aa9100c31979/1

[15] هيئة الزكاة والضريبة والجمارك – لائحة الفوترة الإلكترونية

المادة الثالثة بشأن الخاضعين؛ يحدد تطبيق الربط وفق المتطلبات وإشعار المرحلة المنطبقين.

https://zatca.gov.sa/ar/E-Invoicing/Introduction/LawsAndRegulations/Documents/E-invoicing-Regulations.pdf

[16] البنك المركزي السعودي – الجهات المرخصة لخدمات المدفوعات

قائمة الترخيص الحية؛ للتحقق من كيان مقدم الخدمة ونطاقه وقت اختيار المزود، لا لإثبات مزود بعينه.

https://www.sama.gov.sa/ar-sa/Supervision/LicenseEntities/pages/licensed_payment_service_providers_companies.aspx